

Threat Actor of the Month #001

Threat Actor:
LAPSUS\$

Author:
B Mahidhar

Role:
Security Engineer (Aspiring)
Threat Intelligence | Detection
Engineering | Microsoft Security

Published on 2nd of July 2026

Version
1.0

Executive Summary

Who are they?

LAPSUS\$ is a financially motivated cybercriminal group that gained global attention in late 2021 through a series of high-profile attacks against some of the world's largest technology companies, including Microsoft, NVIDIA, Samsung, Uber, Okta, and others. Unlike many advanced persistent threat (APT) groups that rely heavily on sophisticated malware or zero-day exploits, LAPSUS\$ became known for its unconventional approach of exploiting human trust, identity systems, and organizational processes.

Why are they dangerous?

LAPSUS\$ demonstrated that sophisticated cyberattacks do not always require sophisticated malware. Instead, the group relied heavily on social engineering, credential theft, insider recruitment, SIM swapping, MFA fatigue attacks, and identity-based compromises to obtain privileged access. Once inside an environment, they abused legitimate administrative tools and credential-dumping utilities, such as Mimikatz, to escalate privileges, move laterally, and steal sensitive corporate data.

Main targets:

LAPSUS\$ primarily targeted large enterprises and globally recognized technology companies. Their campaigns attracted significant attention not only because of the high-profile organizations they targeted but also because the group frequently announced or teased future attacks through public messaging platforms and social media. This unusual behavior distinguished them from many traditional cybercriminal groups that typically operate with greater secrecy.

Primary attack techniques:

- Social Engineering
- Insider Recruitment
- SIM Swapping
- MFA Fatigue (Push Bombing)
- Credential Theft
- Valid Accounts
- Privilege Escalation
- Credential Dumping (Mimikatz)
- Active Directory Abuse
- Data Exfiltration
- Public Extortion

Unlike many threat actors that rely primarily on software vulnerabilities, LAPSUS\$ consistently demonstrated a preference for compromising identities and exploiting trusted relationships within organizations before leveraging legitimate administrative tools for further access.

Biggest lesson defenders should learn:

From a defender's perspective, LAPSUS\$ reinforces a critical lesson: **identity has become the primary attack surface in modern cybersecurity.** Strong identity governance, phishing-resistant multi-factor authentication, privileged access management, employee awareness, insider threat programs, and continuous monitoring of authentication activity are no longer optional security controls they are fundamental requirements. Organizations that prioritize perimeter security while overlooking identity governance and human risk remain vulnerable to the same attack patterns that enabled LAPSUS\$ to compromise some of the world's most mature technology companies.

Analyst’s Note (My notes as a threat researcher):

When I first started reading about LAPSUS\$, I expected to find another group that relied heavily on malware or sophisticated exploits. Instead, I found something completely different. What impressed me wasn't the technical complexity of their tools, it was how effectively they manipulated people and identities. That completely changed the way I look at modern cyberattacks. It made me realize that understanding identity security and human behavior is just as important as understanding malware.

Field	Information
Threat Actor Name	LAPSUS\$
Aliases	DEV-0537 (Microsoft), UNC3944
Type	Financially Motivated Cybercriminal Group
Primary Motivation	Financial Gain, Data Theft, Extortion, Public Recognition
First Observed	Publicly active in late 2021
Operational Period	2021–2022 (Peak Activity)
Primary Targets	Technology Companies, Telecommunications, Gaming, Software, Identity Providers
Known Victims	Microsoft, NVIDIA, Samsung, Okta, Uber, Rockstar Games, Electronic Arts, Cisco
Primary Countries Targeted	Global (North America, Europe, South America)
Suspected Origin	Primarily English-speaking members; several members were arrested in the UK. International presence.

Field	Information
Current Status	Several key members were arrested; however, the LAPSUS\$ name and tactics continue to appear.
Primary Initial Access Methods	Social Engineering, Insider Recruitment, SIM Swapping, Credential Theft, MFA Fatigue
Primary Attack Focus	Identity Compromise, Privilege Escalation, Data Exfiltration, Extortion
Notable Characteristic	Relied more on compromising people and identities than exploiting software vulnerabilities. Frequently publicized attacks through Telegram and other public channels.
Skill Level	Moderate technical capability with exceptional social engineering effectiveness
Stealth	Low–Medium (often operated publicly)
Technical Sophistication	Medium
Social Engineering Sophistication	Very High
Identity Abuse	Very High
Likelihood of Insider Recruitment	High

Why This Group Matters (My Perspective):

As someone who recently stepped out of my teenage years, I found LAPSUS\$ fascinating not because of what they did, but because of what they exposed. Their confidence, audacity, and at times even their apparent naivety were enough to compromise some of the world's largest technology companies. It challenged my assumption that successful cyberattacks always require highly sophisticated malware or zero-day exploits. To me, LAPSUS\$ represents a turning point in modern cybersecurity. They demonstrated that compromised identities, weak verification processes, and human trust can be just as dangerous as software vulnerabilities. Studying this group reinforced my belief that identity security, detection engineering, and incident response are becoming more important than ever. There is a lot defenders can learn from their operations because, in many ways, organizations are still adapting to identity-first attacks.

Interesting Facts

- Several suspected members were teenagers at the time of their arrests.
- The group frequently communicated through Telegram instead of operating entirely in secret.
- LAPSUS\$ often announced or hinted at future targets before conducting attacks.
- Their operations relied more on identity compromise and social engineering than sophisticated malware.
- They successfully compromised organizations that were considered to have mature cybersecurity programs.
- Their attacks demonstrated that a single compromised identity can bypass multiple traditional security controls.
- The group helped shift industry attention toward identity-first security strategies.

Timeline:

Late 2021 — Public Emergence

LAPSUS\$ first emerged publicly in **December 2021**, quickly attracting attention through its Telegram channel where the group openly claimed responsibility for cyberattacks. Unlike many financially motivated cybercriminal groups that prefer to remain anonymous, LAPSUS\$ actively sought publicity, building a reputation through bold claims and public interactions.

Initial Access Theme: Social Engineering & Credential Theft

Key Lesson: Modern cybercriminal groups can leverage public attention as part of their operational strategy rather than avoiding it.

February 2022 — NVIDIA Breach

LAPSUS\$ successfully compromised NVIDIA after obtaining employee credentials through social engineering techniques. The attackers exfiltrated approximately 1 TB of sensitive data, including proprietary source code and internal documentation, before attempting to extort the company.

The incident demonstrated that compromising a trusted identity could bypass many traditional security controls without requiring sophisticated malware.

Initial Access: Stolen Credentials

MITRE ATT&CK:

- T1078 – Valid Accounts
- T1003 – OS Credential Dumping

Key Lesson: Protecting privileged identities is just as important as protecting infrastructure.

March 2022 — Samsung Breach

Only weeks after the NVIDIA incident, LAPSUS\$ compromised Samsung and publicly leaked nearly **190 GB** of confidential data, including portions of Galaxy device source code and internal security-related information.

The attack further reinforced the group's ability to repeatedly compromise large technology organizations within a short period.

Initial Access: Identity Compromise

Key Lesson: Intellectual property becomes highly exposed once privileged identities are compromised.

March 2022 — Microsoft Breach

Microsoft confirmed that LAPSUS\$ compromised a limited number of employee accounts and gained access to several internal repositories. Microsoft stated that the attackers primarily relied on identity compromise rather than exploiting vulnerabilities within Microsoft products.

For me, this incident is probably one of the most important in understanding LAPSUS\$. It proved that even organizations with mature security programs remain vulnerable when attackers successfully compromise trusted identities.

Initial Access: Credential Theft & Social Engineering

MITRE ATT&CK:

- T1078 – Valid Accounts
- T1556 – Modify Authentication Process

Key Lesson: Identity security has become one of the most critical layers of modern cybersecurity.

March 2022 — Okta Incident

LAPSUS\$ published screenshots from an Okta support environment after compromising the account of a third-party customer support engineer employed by Sitel (later known as Sykes).

Although the incident affected only a limited support environment, it highlighted how third-party vendors can become indirect entry points into larger organizations.

Initial Access: Third-Party Compromise

Key Lesson: Supply chain security extends beyond software, it also includes people and service providers.

September 2022 — Uber Breach

The Uber incident became one of the most widely discussed examples of MFA fatigue attacks. LAPSUS\$ repeatedly sent MFA push notifications until the targeted employee accepted one of the requests. The attacker then gained internal access and successfully compromised multiple internal systems.

This attack clearly demonstrated that even strong authentication mechanisms can fail when users are manipulated through social engineering.

Initial Access: MFA Fatigue + Social Engineering

MITRE ATT&CK:

- T1621 – Multi-Factor Authentication Request Generation
- T1078 – Valid Accounts

Key Lesson: MFA significantly improves security but cannot fully mitigate human-based attacks.

September 2022 — Rockstar Games Leak

LAPSUS\$ later claimed responsibility for leaking early development footage of **Grand Theft Auto VI**, one of the most anticipated video games in history. Internal communications and development assets were also exposed.

Unlike traditional ransomware operations focused purely on financial extortion, this incident demonstrated the reputational and commercial damage identity-based attacks can cause.

Initial Access: Credential Theft

Key Lesson: Intellectual property is often one of an organization's most valuable assets.

October 2022 — Law Enforcement Action

Throughout 2022, several suspected members associated with LAPSUS\$ were arrested by law enforcement agencies in the United Kingdom. These arrests significantly disrupted the group's public operations.

However, the techniques popularized by LAPSUS\$ particularly identity-focused attacks, social engineering, and insider recruitment continue to be observed across modern cybercrime campaigns.

Key Lesson: Law enforcement can disrupt a group, but successful attack techniques often outlive the people who first popularized them.

Timeline Analysis

Looking back at the timeline, one thing becomes very clear to me. LAPSUS\$ didn't become successful because they had the most advanced malware or the best exploit developers. They became successful because they understood that identities, trust, and human behavior could provide a faster path into an organization than exploiting software vulnerabilities.

Within less than a year, they compromised multiple globally recognized companies across different industries, forcing defenders to rethink what "modern perimeter security" really means. If I had to summarize LAPSUS\$ in one sentence, it would be this:

"They didn't hack the technology first, they hacked the trust that technology depended on."

4. Victimology

Who Did LAPSUS\$ Target?

Unlike many cybercriminal groups that focus on a single industry or geographical region, LAPSUS\$ targeted organizations that held significant business value, public recognition, or privileged access to sensitive information. Their victims ranged from global technology companies and identity providers to telecommunications, gaming, and software organizations.

One of the defining characteristics of LAPSUS\$ was their willingness to target companies with mature security programs. Their victim selection demonstrated that no organization was too large or too security-conscious to become a target if identities and human trust could be exploited.

Geographic Focus

Unlike many nation-state threat actors, LAPSUS\$ did not appear to restrict operations to specific countries. Their campaigns targeted organizations across multiple regions.

Region	Example Organizations
United States	Microsoft, NVIDIA, Okta, Uber
South Korea	Samsung
United Kingdom	Victims and several arrested members
Global	Organizations with worldwide operations

Observation

Rather than targeting countries, LAPSUS\$ targeted global brands. If an organization had valuable data, privileged identities, or public visibility, it became a potential target regardless of its headquarters.

Why These Industries?

After studying LAPSUS\$, I noticed that the group rarely selected victims at random. Their targets generally shared one or more of the following characteristics:

1. High Public Visibility

Compromising well-known companies guaranteed media attention and strengthened the group's reputation within cybercriminal communities.

2. Valuable Intellectual Property

Organizations developing software, hardware, or digital products possessed source code, confidential designs, and internal documentation that could be stolen, leaked, or used for extortion.

3. Identity-Centric Organizations

Companies responsible for authentication or identity management became attractive because compromising a trusted identity could provide access to multiple customers or internal systems.

4. Opportunities for Social Engineering

Organizations with large workforces, help desks, contractors, and third-party vendors presented more opportunities for phishing, SIM swapping, MFA fatigue, and insider recruitment.

5. Financial Motivation

Although LAPSUS\$ frequently sought publicity, many attacks also had clear financial objectives through extortion, ransom demands, or attempts to monetize stolen data.

My Perspective

One thing I found interesting while researching LAPSUS\$ is that they didn't appear to choose victims based solely on technical weaknesses. Instead, they targeted organizations where compromising a trusted identity could produce the greatest operational and reputational impact.

To me, this reinforces an important lesson: attackers often think in terms of business value, not just technical vulnerabilities. Understanding **why** a company is attractive to an attacker is just as important as understanding **how** it was compromised.

5. Initial Access

Pattern 1 — Social Engineering

Overview

Social engineering was one of LAPSUS\$'s primary initial access techniques. Instead of exploiting software vulnerabilities, the group manipulated employees into voluntarily providing credentials, approving authentication requests, or revealing sensitive information.

How it worked

The attackers impersonated trusted individuals such as IT staff or colleagues through phone calls, messaging platforms, or email. They exploited urgency, trust, and human psychology to convince employees to perform actions that ultimately granted unauthorized access.

Why it succeeded

- Human trust
- Weak identity verification
- Help desk procedures
- Lack of employee awareness
- Poor verification policies

MITRE ATT&CK

- T1656 – Impersonation
- T1585 – Establish Accounts (*where relevant*)
- T1078 – Valid Accounts (*result of successful compromise*)

Detection Opportunities

- Multiple failed sign-ins
- Impossible travel
- New device registration
- Unusual authentication patterns
- High-risk sign-ins

Prevention

- Phishing-resistant MFA
- Security awareness
- Help desk verification
- Identity Protection
- Conditional Access

Pattern 2 — SIM Swapping

How it worked

Attackers convinced mobile providers to transfer a victim's phone number to a SIM card under their control, allowing interception of SMS-based MFA codes.

Why it succeeded

Weak carrier verification.

SMS-based MFA.

Social engineering.

Detection

- MFA method changes
- Phone number changes
- Impossible travel

Prevention

FIDO2

Authenticator App

Carrier PIN

Conditional Access

Pattern 3 — Insider Recruitment

Overview

Unlike many cybercriminal groups, LAPSUS\$ actively attempted to recruit employees from targeted organizations by offering financial incentives in exchange for credentials or privileged access.

Why it succeeded

Money

Privileged access.

Weak insider monitoring.

Detection

- Unusual privileged activity
- Large data access
- New admin accounts
- Insider risk alerts

Prevention

- Insider Risk Management
- Least Privilege
- PIM
- UEBA

Pattern 4 — MFA Fatigue

How it worked

Repeated MFA prompts until the user approved one.

Why it worked

User annoyance.

Trust.

No number matching.

Detection

- Multiple MFA requests
- Risky sign-ins
- Authentication anomalies

Prevention

- Number Matching
- Passwordless
- FIDO2

Pattern 5 — Credential Theft

How it worked

Obtained credentials through phishing, social engineering, previous breaches, or insider access.

Why it succeeded

Password reuse.

Weak passwords.

Lack of MFA.

Detection

- Credential stuffing
- Impossible travel
- Risky Users
- Sign-in Risk

Prevention

- Passwordless
- Identity Protection
- Password policies

6. Attack Chain

Objective: Understand how LAPSUS\$ progresses from an external attacker to complete organizational compromise.

Reconnaissance



Target Selection



Social Engineering / Insider Recruitment



Credential Theft



SIM Swapping / MFA Fatigue



Valid Account Access



Privilege Escalation



Internal Discovery



Credential Dumping



Lateral Movement



Data Collection



Data Exfiltration



Public Extortion / Data Leak

Stage 1 — Reconnaissance

Objective

Identify employees, contractors, administrators, vendors, and potential insiders who can provide access.

Activities

- LinkedIn research
- Social media profiling
- Company structure mapping
- Employee email collection
- Vendor identification

MITRE

- Gather Victim Identity Information
- Gather Victim Network Information

Defender Perspective:

This stage rarely generates internal logs.

OSINT awareness and employee training become the primary defenses.

Stage 2 — Initial Access

Objective

Gain a trusted identity.

Common Techniques:

- Social Engineering
- Insider Recruitment
- SIM Swapping
- Phishing
- Credential Theft

Why it Matters:

LAPSUS\$ often skipped exploiting software entirely.

They attacked trust instead.

Stage 3 — Authentication Bypass

After obtaining credentials, attackers bypassed authentication controls using:

- MFA Fatigue
- SIM Swapping
- Stolen Session Tokens
- Existing Valid Sessions

Investigation

- Impossible Travel
- Multiple MFA prompts
- New device registration
- Risky Sign-ins

Stage 4 — Account Compromise

Once authenticated...The attacker became a legitimate user.

This changes everything.

Activities

- Email access
- Teams access
- VPN
- Internal portals

Detection

Identity becomes your primary telemetry.

Stage 5 — Privilege Escalation

Now they want more power.

Activities

- Credential dumping
- Mimikatz
- Token manipulation
- Pass-the-Hash
- Pass-the-Ticket

Goal:

Become Domain Admin.

Stage 6 — Internal Discovery

Before stealing data...Understand the environment.

Activities

- Enumerate users
- Enumerate groups
- Discover servers
- Identify repositories
- Identify backups

Stage 7 — Lateral Movement

Move across the organization.

Examples

- SMB (Server Message Block)
- RDP (Remote Desktop Protocol)
- PsExec - A lightweight, command-line tool from the Microsoft Sysinternals suite that lets you execute processes on remote systems interactively.
- Remote PowerShell

Stage 8 — Data Collection

Now collect

- Source code
- Internal documents
- Credentials
- Intellectual Property
- Authentication material

Stage 9 — Data Exfiltration

Transfer data outside.

- Cloud storage
- Personal servers
- Encrypted archives

Stage 10 — Extortion

Unlike ransomware groups...LAPSUS\$often preferred Public pressure.

Activities

- Telegram posts
- Data leaks
- Public announcements
- Extortion

If I Were Investigating This Attack

The first question I would ask is **not** "What malware did they use?"

It would be:

Which identity was compromised first?

From there, I would reconstruct the attack chronologically:

1. Identify the initial compromised account.
2. Review sign-in history and authentication logs.
3. Determine how the credentials were obtained.
4. Check for MFA abuse or SIM-swapping indicators.
5. Map privilege escalation activities.
6. Identify lateral movement between systems.
7. Determine what data was accessed or exfiltrated.
8. Assess business impact and begin containment.

Studying LAPSUS\$ reinforced an important lesson for me: in identity-driven attacks, the investigation often begins with authentication logs rather than endpoint malware. Understanding **who** logged in, **from where**, **using which identity**, and **how that identity was abused** is often the fastest path to understanding the entire intrusion.

7. MITRE ATT&CK Mapping:

ATT&CK Tactic	Technique	Technique ID	Observed in LAPSUS\$
Reconnaissance	Gather Victim Identity Information	T1589	Employee names, roles, contact information collected before attacks.
Reconnaissance	Gather Victim Network Information	T1590	Public information gathered about target environments.
Resource Development	Compromise Accounts	T1586	Use of compromised identities to gain initial access.
Initial Access	Valid Accounts	T1078	Stolen employee credentials used to authenticate into corporate environments.
Initial Access	Phishing / Social Engineering	T1566	Employees manipulated into revealing credentials or approving authentication requests.
Credential Access	OS Credential Dumping	T1003	Credential dumping tools such as Mimikatz used after initial compromise.
Credential Access	LSASS Memory	T1003.001	Credentials extracted from LSASS memory where applicable.
Credential Access	Security Account Manager (SAM)	T1003.002	Local account credential extraction.
Credential Access	DCSync	T1003.006	Domain credential replication abuse observed in Active Directory environments.
Credential Access	Pass the Hash	T1550.002	NTLM hashes reused for authentication.
Credential Access	Pass the Ticket	T1550.003	Kerberos tickets reused to access resources.

ATT&CK Tactic	Technique	Technique ID	Observed in LAPSUS\$
Discovery	Account Discovery	T1087	Enumeration of users and privileged accounts.
Discovery	Domain Trust Discovery	T1482	Identification of Active Directory trust relationships.
Discovery	Network Service Scanning	T1046	Internal network reconnaissance after compromise.
Lateral Movement	Remote Services	T1021	RDP, SMB, PsExec, and PowerShell Remoting used to move across systems.
Privilege Escalation	Access Token Manipulation	T1134	Abuse of Windows access tokens to elevate privileges.
Collection	Data from Information Repositories	T1213	Source code, documents, and internal repositories collected.
Collection	Archive Collected Data	T1560	Sensitive files archived before exfiltration.
Exfiltration	Exfiltration Over Web Services	T1567	Data transferred to attacker-controlled cloud services.
Impact	Data Manipulation / Extortion	T1657	Stolen data used for extortion and public leaks.

Key Techniques Observed

The following techniques appeared repeatedly throughout LAPSUS\$ operations and formed the foundation of many of their successful compromises:

- **T1078 – Valid Accounts**
- **T1566 – Phishing / Social Engineering**
- **T1003 – OS Credential Dumping**
- **T1550 – Use Alternate Authentication Material (Pass the Hash / Pass the Ticket)**
- **T1021 – Remote Services**
- **T1213 – Data from Information Repositories**

My Analysis

One observation that stood out while mapping LAPSUS\$ to the MITRE ATT&CK framework is that the group relied heavily on **identity abuse** rather than software exploitation. Many of the techniques they employed centered around obtaining legitimate credentials and abusing trusted authentication mechanisms instead of deploying custom malware. This reinforces the idea that defending identities is often just as important as defending endpoints or networks.

8. Detection Opportunities

Objective: Identify detection opportunities across the attack lifecycle and map them to security telemetry that defenders can monitor.

Stage 1 – Reconnaissance

Possible Indicators

- Unusual external reconnaissance of employee profiles
- Large-scale LinkedIn scraping (*limited internal visibility*)
- Enumeration of publicly available email addresses

Detection Opportunities

- Monitor abnormal requests to public-facing employee directories
- Threat Intelligence monitoring for brand mentions
- Dark Web monitoring for leaked employee information

Stage 2 – Social Engineering

Possible Indicators

- Multiple password reset requests
- Helpdesk verification requests
- Unusual MFA enrollment attempts
- Suspicious phone number changes

Detection Opportunities

- Password Reset Spike
- Authentication Method Changes
- New Authentication Method Registered
- Risky User Detection

Stage 3 – Credential Theft

Possible Indicators

- Impossible Travel
- Unfamiliar Sign-in Properties
- Multiple Failed Sign-ins
- Anonymous IP Usage
- Sign-ins from TOR Exit Nodes

Detection Opportunities

- Impossible Travel
- Risky Sign-ins
- Atypical Travel
- Failed Login Spike
- Impossible Device Change

Stage 4 – Account Compromise

Possible Indicators

- New device registration
- Privileged role activation
- Abnormal sign-in locations
- Concurrent sessions

Detection Opportunities

- Privileged Identity Changes
- Role Assignment Monitoring
- Conditional Access Failures
- Identity Protection Alerts

Stage 5 – Privilege Escalation

Possible Indicators

- Domain Admin membership changes
- New privileged accounts
- LSASS access
- Mimikatz behavior
- Credential dumping

Detection Opportunities

- Defender for Endpoint credential dumping alerts
- Security Event ID 4672
- Security Event ID 4624
- Defender XDR privilege escalation incidents

Stage 6 – Internal Discovery

Possible Indicators

- PowerShell enumeration
- Active Directory queries
- LDAP enumeration
- Network scanning

Detection Opportunities

- Defender XDR Discovery Alerts
- PowerShell Logging
- Event ID 4104
- Sysmon Event ID 1

Stage 7 – Lateral Movement

Possible Indicators

- PsExec execution
- SMB connections
- Remote PowerShell
- RDP authentication

Detection Opportunities

- Event ID 4624 (Type 10)
- Sysmon Event ID 3
- Defender Lateral Movement Alerts

Stage 8 – Data Collection

Possible Indicators

- Large repository access
- Archive creation
- Mass file access
- Source code downloads

Detection Opportunities

- File Access Monitoring
- Defender Insider Risk
- Microsoft Purview Alerts

Stage 9 – Data Exfiltration

Possible Indicators

- Large outbound transfers
- Cloud storage uploads
- Archive uploads

Detection Opportunities

- Defender for Cloud Apps
- Unusual Data Transfer
- Microsoft Purview DLP

Microsoft Security Perspective

Analytics Rules

Recommended detections:

- Impossible Travel
- MFA Fatigue
- Multiple Failed Sign-ins
- Suspicious Privileged Role Assignment
- Password Reset Spike
- New Device Registration
- Impossible Device Change
- Credential Dumping Detection

Hunting Queries

Investigate:

- Risky Users
- Privileged Accounts
- Failed Authentication
- MFA Events
- New Authentication Methods

KQL Queries: I'm currently learning KQL as part of my SC-200 journey. Rather than including queries I don't fully understand, I've intentionally left this section blank. Future reports in this series will include KQL hunting queries written as my understanding develops.

Automation

Microsoft Sentinel Playbooks could automatically:

- Disable compromised accounts
- Notify the SOC
- Create an Incident
- Block risky IP addresses
- Require password reset
- Trigger Conditional Access

Microsoft Defender XDR

Relevant Products

- Defender for Endpoint
- Defender for Identity
- Defender for Office 365
- Defender for Cloud Apps

Potential Alerts

- Credential Dumping
- Pass-the-Hash
- Pass-the-Ticket
- Suspicious PowerShell
- Mimikatz Detection
- Lateral Movement
- RDP Abuse
- Unusual Sign-in Activity

Investigation

Correlate:

- Identity
- Device
- Network
- Email
- Cloud

One incident timeline instead of isolated alerts.

Microsoft Entra ID

Identity Protection

Monitor:

- Risky Users
- Risky Sign-ins
- Impossible Travel

- Anonymous IP
- Leaked Credentials

Conditional Access

Policies:

- Block Legacy Authentication
- Require MFA
- Require Compliant Device
- Restrict High-Risk Sign-ins

Privileged Identity Management (PIM)

Use Just-in-Time Administration

Monitor:

- Permanent role assignments
- New Global Administrators
- Emergency access accounts

Multi-Factor Authentication

Prefer:

- FIDO2 Security Keys
- Windows Hello for Business
- Microsoft Authenticator with Number Matching

Avoid SMS-based MFA wherever possible because SIM swapping was one of the techniques associated with identity-focused attacks like those used by LAPSUS\$.

My Perspective

While researching LAPSUS\$, one thing became increasingly clear to me: Microsoft provides most of the telemetry needed to investigate identity-based attacks—but telemetry alone isn't enough. The real challenge is correlating identity, endpoint, and cloud signals into a single investigation. That's where Microsoft Sentinel, Defender XDR, and Entra ID work best together. Studying this group reinforced my belief that modern SOC analysts need to think across identities, endpoints, and cloud services rather than treating them as separate investigations.

9. Incident Response

Scenario: You are the on-call SOC Analyst. Microsoft Sentinel has generated multiple high-severity incidents indicating suspicious sign-ins, MFA fatigue activity, and potential credential compromise against privileged accounts.

First 15 Minutes — Initial Triage

Objective

Determine whether this is a legitimate security incident or a false positive.

Immediate Actions

- Review the Sentinel incident details.
- Identify the affected user account(s).
- Check **Microsoft Entra ID Sign-in Logs**.
- Verify:
 - Source IP address
 - Geographic location
 - Device information
 - Authentication method
 - Risk level
- Contact the affected user (out-of-band if possible) to validate recent activity.
- Determine whether the MFA prompts were expected or suspicious.

Questions I'd Ask

- Did the user initiate this sign-in?
- Is this a managed device?
- Is the IP address known?
- Has this user experienced similar alerts before?
- Are there other affected accounts?

First Hour — Investigation

Objective

Determine the scope of the compromise.

Identity Investigation

- Review SigninLogs.
- Review AuditLogs.
- Check Risky Users.

- Review Risky Sign-ins.
- Check authentication method changes.
- Review password reset activity.
- Look for new MFA registrations.

Endpoint Investigation

- Check Defender for Endpoint.
- Look for:
 - Mimikatz
 - LSASS access
 - Suspicious PowerShell
 - Credential dumping
 - PsExec execution

Lateral Movement

Investigate:

- SMB connections
- RDP sessions
- Remote PowerShell
- Privileged account usage
- New device registrations

Questions I'd Ask

- Was only one account compromised?
- Has privilege escalation occurred?
- Was sensitive data accessed?
- Has data already left the environment?

Containment

Objective

Prevent further attacker activity while minimizing business disruption.

Identity

- Disable compromised accounts.
- Revoke active sessions.
- Force password reset.
- Require MFA re-registration.
- Block high-risk sign-ins.

Endpoint

- Isolate compromised devices.
- Stop malicious processes.
- Block identified hashes and IOCs.

Network

- Block malicious IP addresses.
- Restrict suspicious VPN sessions.
- Review firewall logs.

Communication

Notify:

- SOC Manager
- Incident Response Team
- Identity Team
- Management (if required)

Eradication

Objective

Remove attacker persistence and eliminate the root cause.

Activities

- Remove unauthorized accounts.
- Remove persistence mechanisms.
- Reset privileged credentials.
- Rotate service account passwords.
- Remove unauthorized MFA devices.
- Verify Conditional Access policies.
- Patch any discovered weaknesses.
- Review privileged group memberships.

Validation

Confirm:

- No malicious sessions remain.
- No attacker-controlled accounts exist.
- No scheduled tasks or persistence mechanisms remain.
- Identity risks have returned to normal.

Recovery

Objective

Safely restore normal business operations.

Activities

- Re-enable user access after verification.
- Restore isolated systems.
- Continue enhanced monitoring.
- Validate business applications.
- Confirm no further suspicious authentication activity.

Post-Incident

Conduct:

- Root Cause Analysis
- Lessons Learned
- Timeline reconstruction
- Detection improvements
- Playbook updates

Lessons Learned

This is probably my favorite section.

If I were defending against LAPSUS\$, my post-incident recommendations would be:

- Move away from SMS-based MFA wherever possible.
- Deploy phishing-resistant MFA (FIDO2 or Windows Hello for Business).
- Strengthen helpdesk identity verification procedures.
- Continuously monitor privileged identities.
- Implement Just-in-Time administration using PIM.
- Improve employee awareness around MFA fatigue and social engineering.
- Expand telemetry collection for identity-based investigations.

My Analysis:

If I ever investigate an incident similar to LAPSUS\$, I don't think my first instinct would be to hunt for malware. Instead, I'd begin with the compromised identity. I'd want to understand **who authenticated, how they authenticated, from where they authenticated, and what they accessed immediately afterward**. Once that timeline is clear, everything else privilege escalation, lateral movement, and data access—becomes much easier to reconstruct.

This report reinforced something I've come to appreciate while studying identity security: in many modern attacks, the user's identity is the initial entry point, the attack path, and sometimes even the evidence needed to solve the case.

10. References

The following resources were used to research and validate the information presented in this report.

Official Sources

- Microsoft Security Blog
- Microsoft Threat Intelligence
- MITRE ATT&CK Framework
- CISA (Cybersecurity & Infrastructure Security Agency)
- Google Threat Intelligence (formerly Mandiant)
- CrowdStrike Intelligence
- NVIDIA Security Statement
- Okta Security Advisory
- Uber Security Update
- Samsung Security Statement

Additional Reading

- Recorded Future Threat Intelligence
- The DFIR Report (where applicable)
- Public incident reports and security advisories

Author's Note

This report reflects my own research, understanding, and analysis of LAPSUS\$. AI tools were used as writing assistants to help improve structure, readability, and review technical concepts. All conclusions, personal analysis, and learning points represent my own understanding at the time of writing.

Tools Used

- ChatGPT
- Gemini

11. Skills Practiced:

- Threat Intelligence
- Threat Actor Research
- MITRE ATT&CK Mapping
- Incident Response
- Identity Security
- Detection Engineering
- Microsoft Sentinel Concepts
- Microsoft Defender XDR Concepts

- Microsoft Entra ID Security
- Security Writing
- Documentation
- Critical Thinking
- KQL (Learning in progress)

12. Next Threat Actor

Coming Next...

Threat Actor of the Month #002

 TBD, Stay Tuned.

Final Note 🙌 :

Thank you for taking the time to read my first threat intelligence report. This project is part of my journey toward becoming a better security investigator and detection engineer. Every report in this series is an opportunity for me to learn something new, improve my analytical thinking, and document my progress. If you have feedback or suggestions, I'd genuinely appreciate hearing them.

Until the next threat actor...stay curious and keep investigating.

— B Mahidhar

